

docs/modules/attachments.md

Attachments - Ҳужжатга файл бириктириш (Arbitr-013) - SPEC

ҲОЛАТ: БАЖАРИЛГАН (2026-07-08, changeset 042).

Мақсад

QBO Attachments паритети: ҳар транзакция ҳужжатига файл бириктириш (банк кўчирмаси, ҳисоб-фактура скани, шартнома). GL'га мутлақо тегмайди - соф ҳужжат иловаси қуйи тизими.

Қатъий қарорлар

- **Сақлаш: локал диск, базада фақат метамаълумот.** Базага bytea ЁЗИЛМАЙДИ (backup/қувват оғирлашади). Каталог application.yml'да: `app.attachments.dir` (default `./attachments`, `.gitignore`'га кирази; серверда конфиг билан алоҳида йўлга қўйилади).
- **Диск номи сервер яратади:** `йил/ой/UUID.кенгайтма` (масалан `2026/07/0197...f3.pdf`) - фойдаланувчи киритган ном диск йўлига ҲЕЧ ҚАЧОН кирмайди (path traversal ҳимояси). Асл ном фақат базада, юклаб олишда қайтарилади.
- **Чеклов:** 20MB (QBO паритети); кенгайтма allowlist: pdf, png, jpg, jpeg, webp, gif, xlsx, xls, docx, doc, csv, txt, zip.
- **Полиморф боғланиш:** `document_type` (DocumentType enum номи) + `document_id`. FK йўқ (полиморф) - сервис target ҳужжат мавжудлигини ўзи текширади (BR-ATT-003).
- **POSTED ҳужжатга ҳам бириктириш/ўчириш мумкин** - illova GL эмас, темир қоида 3 бузилмайди (QBO ҳам рухсат беради).
- **Роллар:** соҳада EDIT рухсати бор роллар юклайди ва ўчиради; view-only роллар (VIEWER_AUDITOR) фақат рўйхатни кўради ва юклаб олади.
- **Ўчириш қатъий** (диск + база бирга). Илова тарихи талаб қилинмайди - versioning ҲАЛИ ЙЎҚ.

Модел (changeset 042 - рақам банд қилинган)

Attachment (attachment) - янги

Майдон	Тип	Изоҳ
document_type	varchar(30) NOT NULL	DocumentType enum номи (INVOICE, BILL, ...)
document_id	UUID NOT NULL	Target ҳужжат id (полиморф, FK'сиз)
original_name	varchar(255) NOT NULL	Фойдаланувчи файл номи (кўрсатиш/юклаб олиш учун)
stored_path	varchar(255) NOT NULL	app.attachments.dir'га нисбий йўл (йил/ой/UUID.ext)
content_type	varchar(100) NOT NULL	MIME (browser'дан, кўрсатиш учун)
size_bytes	bigint NOT NULL	Ҳажм (рўйхатда Fmt билан кўрсатилади)

- BaseEntity устунлари (id, version, audit, created_by - ким юклагани).

- Индекс: `idx_attachment_document (document_type, document_id)`.
- Rollback: DROP TABLE.

Service API (attachment модули)

AttachmentService (бошқа модуллар мурожаат ҚИЛМАЙДИ - фақат ўз web қатлами; ledger'га боғлиқлик йўқ):

- `list(DocumentType, UUID)` - ҳужжат иловалари (сана DESC).
- `upload(DocumentType, UUID, MultipartFile)` - валидация (BR-ATT-001/ 002/003) + дискка ёзиш + метамаълумот сақлаш.
- `download(UUID)` - Resource + асл ном (Content-Disposition).
- `delete(UUID)` - база ёзуви + диск файли бирга ўчади.

Target мавжудлиги текшируви: ҳар modul repository'сига қўл узатмасдан - битта JdbcClient `SELECT EXISTS` (жадвал номи DocumentType'дан map қилинади, LedgerDashboardService хом SQL прецеденти).

Posting

GL'га тегилмайди. PostingService УМУМАН import қилинмайди (Est/PO қолипдаги review checkpoint). Тест: upload/delete'да journal_entry сони ўзгармайди.

Валидация (BR-ATT)

Код	Қоида
BR-ATT-001	Файл ҳажми 20MB дан ошмайди (multipart чеклови ҳам конфигда)
BR-ATT-002	Кенгайтма allowlist'да бўлиши шарт (регистрга қарамай)
BR-ATT-003	Target ҳужжат (document_type + document_id) мавжуд бўлиши шарт
BR-ATT-004	EDIT рухсатисиз роллар (масалан VIEWER_AUDITOR) юклай/ўчира олмайди (Spring Security қатламида 403)

Экранлар (JTE routes)

Алоҳида саҳифа ЙЎҚ - ҳар транзакция КЎРИШ экранида «Иловалар» бўлими (`shared/attachments.jte` partial): рўйхат (ном, ҳажм, сана, ким) + юклаш формаси (multipart, CSRF hidden token) + юклаб олиш линки + ўчириш (confirm). Қамров: invoice, bill, банк транзакцияси (expense/ deposit кўриши), transfer, JE + Returns/Estimate/PO кўришлари (14-16 турткилари тугагач мавжуд бўлади).

- Кўриш UX (Arbitr-094, DEPLOY 4): расм иловалар inline кўринади, PDF модал ичида очилади; clipboard'дан paste билан юклаш ишлайди; SVG юклаш ТАҚИҚ (XSS хавфи - allowlist'га атайлаб киритилмаган).
- `POST /attachments/{type}/{id}` - юклаш (redirect ортга).
- `GET /attachments/{id}/download` - юклаб олиш.
- `POST /attachments/{id}/delete` - ўчириш.
- Конфиг: `spring.servlet.multipart.max-file-size=20MB` (+ request).
- 375px: рўйхат .table-wrap ичида, форма бир устун.

Тестлар (мажбурий рўйхат)

1. Upload → дискда файл бор + база ёзуви тўғри; download асл ном билан қайтади.
2. 20MB дан катта файл рад (BR-ATT-001).
3. exe/рухсатсиз кенгайтма рад (BR-ATT-002).
4. Мавжуд бўлмаган target рад (BR-ATT-003).
5. VIEWER_AUDITOR upload/delete 403, download/рўйхат ишлайди (BR-ATT-004).
6. Delete базадан ҲАМ дискдан ҲАМ ўчиради.
7. Upload/delete'да journal_entry сони ўзгармайди (GL'сизлик assert).
8. Path traversal: original_name'да `../` бўлса ҳам stored_path сервере UUID қолипида (assert).
9. Тестда каталог: test профилида `app.attachments.dir` build/ ости вақтинчалик папкага йўналтирилади (лойиҳа папкаси ифлосланмайди).